

38. Auditoría informática

Concepto y contenidos
Administración, planeamiento, organización, infraestructura técnica y prácticas operativas

udima
UNIVERSIDAD A DISTANCIA DE MADRID

Enero 2026

Índice

- Conceptos básicos: Auditorías, pruebas y controles

- Metodología:
  - Fases de la auditoría: Planificación, Ejecución e Informe
  - Perfil del auditor. Equipo de auditoría ENS (Guía CCN-STIC 802)

- Normas y estándares:
  - Ámbito nacional:
    - Auditoría de protección de datos personales: RGPD y LOPD
    - **Auditoría de seguridad: ENS, ITS y Guías CCN-STIC**

  - Estándares internacionales:
    - ISO 27000 (SGSI), ISO 15408 (Common Criteria), ISO 19011 (Directrices auditoría), ISO 17000
    - COBIT (Control Objectives for Information Technologies)

- Herramientas:
  - CAATs
  - Herramientas CCN

OEP 2023

10. Según la guía CCN-STIC-802, el equipo auditor deberá estar dirigido y tutelado siempre por un Auditor Jefe, responsable de gestionar las actividades de auditoría, que deberá probar como mínimo:

a) Acreditación de formación y experiencia en auditoría de sistemas de información, a través de certificaciones reconocidas a nivel nacional e internacional, o bien a través de experiencia verificable y evidenciada de al menos 4 años, en auditoría de tecnologías de la información.

b) Acreditación de formación y experiencia en auditoría de sistemas de información, a través de certificaciones reconocidas a nivel nacional e internacional, o bien a través de experiencia verificable y evidenciada de al menos 5 años, en auditoría de tecnologías de la información.

c) Acreditación de formación y experiencia en auditoría de sistemas de información, a través de certificaciones reconocidas a nivel exclusivamente nacional, o bien a través de experiencia verificable y evidenciada de al menos 5 años, en auditoría de tecnologías de la información.

d) Acreditación de formación y experiencia en auditoría de sistemas de información, a través de certificaciones reconocidas a nivel exclusivamente nacional, o bien a través de experiencia verificable y evidenciada de al menos 4 años, en auditoría de tecnologías de la información.

51. ¿Cuál es la guía que articula el mecanismo de Declaración y Certificación de Conformidad con el Esquema Nacional de Seguridad (ENS), determinando las condiciones para alcanzar dicho cumplimiento normativo?

a) Guía CCN-STIC 812.

b) Guía CCN-STIC 823.

c) Guía CCN-STIC 809.

d) Guía CCN-STIC 803.

Preguntas años anteriores…

OEP 2022

Convocatoria ordinaria (oct-23)

64. ¿Cuál de las siguientes afirmaciones describe mejor el propósito de una auditoría informática de nivel experto?:

a) Evaluar el rendimiento de la infraestructura técnica de una organización.
b) Identificar vulnerabilidades y riesgos de seguridad en los sistemas de información.
c) Revisar la gestión financiera de la empresa en relación con la tecnología.
d) Supervisar el cumplimiento de las políticas de recursos humanos en TI.

80. La norma ISO/IEC 27001:2022:

a) Es un estándar comúnmente aceptado para la gestión de riesgos de seguridad de la información.
b) Disponer de una certificación bajo esta norma ISO supone el cumplimiento del Esquema Nacional de Seguridad, ya que existe una equivalencia entre ambos estándares formalmente reconocida en el RD 311/2022 por el que se regula el Esquema Nacional de Seguridad.
c) No es certificable.
d) Es un estándar comúnmente aceptado para la implantación de sistemas de gestión de seguridad de la información, (o ISMS - information security management systems por sus siglas en inglés.

102. ¿Cuál es el plazo que establece el RGPD (Reglamento General de Protección de Datos), (UE) 2016/679, como obligación para la realización de una auditoría de protección de datos?:

a) Cada 2 años de forma general, al realizar una evaluación de conformidad.
b) Cada año para los sistemas de alto riesgo que requieran EIPD (Evaluación de Impacto de Protección de Datos), cada dos años para el resto.
c) No establece un plazo. La Autoridad de Control determina cuándo realizar auditorías de protección de datos.
d) Cada vez que se realice un cambio significativo en el perfil de riesgo del sistema.

OEP 2020 Ordinaria (mayo-22)

11. Según el Anexo A de la Guía de Seguridad de las TIC CCN-STIC 802, ¿cuál de los siguientes NO es un requisito que deba probar el Auditor Jefe?:

a) Acreditación de formación y experiencia en auditoría de cuentas.

b) Conocimientos de seguridad y gestión de riesgos de seguridad.

c) Conocimiento de los requisitos del Real Decreto 3/2010.

d) Conocimientos de otra legislación aplicable cuando la auditoría incluya además otros requisitos o esquemas de seguridad.

52. ¿Cuál de las siguientes respuestas es CORRECTA referente a las auditorías que se plantean en el RGPD?:

a) Hay obligación de realizar auditorías periódicas preventivas según dispone el RGPD.

b) Solo se tendrán que realizar auditorías cuando lo exija la AEPD.

c) Pueden realizarse auditorías de cumplimiento a decisión de la organización sin que las haya solicitado la AEPD.

d) Las auditorías del RGPD tienen que ser siempre realizadas por un auditor certificado.

Preguntas años anteriores…

OEP 2020 (extraordinaria)

8. Atendiendo al Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica, indique cuál de las siguientes respuestas es INCORRECTA en relación con un sistema de información de categoría alta:

a) Será objeto de una auditoría regular ordinaria, al menos cada dos años.

b) Deberá realizarse una auditoría extraordinaria siempre que se produzcan modificaciones sustanciales en el sistema de información, que puedan repercutir en las medidas de seguridad requeridas.

c) Los informes de auditoría serán presentados al responsable del sistema y al responsable de seguridad competentes.

d) Los informes de auditoría serán analizados por el responsable del sistema.

9. Indique cuál es la denominación de la modalidad de auditoria dirigida a verificar las distintas fases del ciclo de vida del desarrollo de un proyecto:

a) Auditoría de la dirección de tecnologías de la información.

b) Auditoría de equipamiento informático.

c) Auditoría de la contratación de bienes y servicios TIC.

d) Auditoría de los desarrollos y mantenimiento de los sistemas de información.

19. Según el Real Decreto 311/2022, para determinar la conformidad con el Esquema Nacional de Seguridad se exige:

a) Superar una auditoría de conformidad, o realizar una autoevaluación, en el caso de sistemas de categoría básica.

b) Superar una auditoría de conformidad, en cualquier caso.

c) Preparar y aprobar la política de seguridad, categorizar los sistemas e implantar las medidas de seguridad.

d) Preparar y aprobar la política de seguridad, categorizar los sistemas, implantar las medidas de seguridad y realizar un análisis de riesgos.

Preguntas años anteriores…

OEP 2019 (ordinaria)

93. Atendiendo al Real Decreto 3/2010 por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica, señale la opción correcta sobre la realización de auditorías de seguridad en los sistemas de información de categoría básica:

a. No necesitan realizar una auditoría.
b. Deben ser objeto de una auditoría al menos anualmente.
c. Deben ser objeto de una auditoría al menos cada dos años.
d. Deben ser objeto de auditoría cuando se produzcan modificaciones sustanciales en el sistema de información.

100. La herramienta desarrollada por el Centro Criptológico Nacional que permite a las Administraciones Públicas realizar el análisis y la gestión de riesgos, así como el análisis del impacto y la continuidad de operaciones para las Administraciones Públicas se denomina:

a. MAGERIT.
b. PILAR.
c. ANGELES.
d. LUCIA.

OEP 2019 (extraordinaria)

10. Los sistemas de información de categoría media conforme al Esquema Nacional de Seguridad, aprobado por Real Decreto 3/2010, de 8 de enero serán objeto de una auditoría regular ordinaria:

a. Una vez al año cuando contengan datos personales de acuerdo al Reglamento General de Protección de Datos.
b. Cada tres años si no contienen datos personales.
c. Al menos cada dos años y con carácter extraordinario siempre que se produzcan modificaciones sustanciales que puedan repercutir en las medidas de seguridad requeridas.
d. Trimestralmente.

- Auditoría informática [Ron Weber, 1982]: proceso de recoger, agrupar y evaluar evidencias para determinar si un sistema de información:
  - salvaguarda los activos,
  - mantiene la integridad de los datos,
  - lleva a cabo los fines de la organización
  - y utiliza eficientemente los recursos.

- Auditoría de la seguridad [ENS, RD 311/22]: es un proceso sistemático, **independiente** y documentado que persigue la obtención de evidencias objetivas y su evaluación objetiva para determinar en qué medida se cumplen los criterios de auditoría en relación con la idoneidad de los controles de seguridad adoptados, el cumplimiento de la política de seguridad, las normas y los procedimientos operativos establecidos, y detectando desviaciones a los antedichos criterios.
  - Definición basada en la ofrecida por la ISO 9000.

Objetivos de la auditoría

- 5 funciones “clásicas”: Análisis/revisión/verificación/evaluación de:
  - La **eficacia** de los sistemas en cuanto a la consecución de los objetivos que persigue.
  - La **eficiencia** en la gestión de los recursos.
  - El cumplimiento de la **normativa y estándares**.
  - Asegurar la **seguridad** del sistema (dimensiones ACID-T).
  - Garantizar la **calidad** del sistema.

- Más definiciones:
  - Supervisión de los **controles** implementados para proteger los activos (seguridad) y determinación de la eficiencia de los mismos.
  - Auditar es una función de **evaluación independiente** para examinar y evaluar las actividades de una organización y sus resultados [CAF 2020].

Tipos de auditorías

- Según quién la realiza:
  - **Interna**: realizada por personas de la organización objeto de la auditoría.
  - **Externa**: realizada por personas ajenas.

- "Por partes":
  - Auditoría de **1ª parte**:
    - Hecha por personal interno.
    - Típicamente para mejorar el mantenimiento del sistema (MSI), su calidad, eficacia y/o eficiencia.
    - El auditor debe estar libre de responsabilidades en el sistema que se audita.

  - Auditoría de **2ª parte**:
    - Hecha por alguien que tiene algún interés en la organización auditada.
    - Ejemplo: el cliente (o alguien en su nombre) audita a su proveedor IT.
    - Externa, pero no totalmente independiente.

  - Auditoría de **3ª parte**:
    - Hecha por personal independiente de la organización. Externa.
    - Previa a una certificación, por obligación legal (ENS) o por cumplimiento de estándares.

- Según Ley General Presupuestaria (artículo 162 y siguientes):

  - **Auditoría pública**: verificación, realizada con posterioridad y efectuada de forma sistemática, de la actividad económico-financiera del sector público estatal, mediante la aplicación de los procedimientos de revisión selectivos contenidos en las normas de auditoría e instrucciones que dicte la IGAE.

  - Modalidades de auditoría pública:
    a) Auditoría de regularidad contable.
    b) Auditoría de las cuentas anuales: subtipo de la anterior.
    c) Auditoría de cumplimiento, conformidad con las normas económico-financieras que les son de aplicación.
    d) Auditoría operativa: adecuación a los principios de la buena gestión económico-financieras, con la finalidad de evaluar el nivel de eficacia, eficiencia y economía. No trasciende normalmente al ámbito de la organización.

  - Plan anual de auditorías de la IGAE.

  - Desarrollo en Normas de Auditoría del Sector Público (NASP, actualizadas en 2019).

Tipos de auditorías

- Auditoría informática (Ron Weber).
- Auditoría de seguridad (ENS).
- Auditoría pública (económico-financiera, IGAE).

- Auditoría forense: descubrir fraudes y delitos, obtener evidencias válidas para su uso por las autoridades competentes, policiales o judiciales.

- Auditoría de desarrollo y mantenimiento: verificar las distintas fases del ciclo de vida de un sistema TIC.

- Auditoría de equipamiento TIC: HW y/o SW.

- Auditoría de explotación y operación de sistemas.

- Auditoría de comunicaciones.

- Auditoría de contratación de bienes y servicios TIC.

- Auditoría de protección de datos personales.
- …

Control

- Regulación, manual o automática, sobre un sistema.
- Mecanismo o procedimiento que evita, previene o detecta un riesgo.
- En el contexto de una auditoría, estos pueden ser clasificados en:
  - Detectivos: detecta la aparición del riesgo.
  - Correctivos: corrige un riesgo, error, omisión o acto deliberado antes de que haya pérdidas.
  - Preventivos: evita un riesgo, error, omisión o acto deliberado.

Pruebas de auditoría

- Permiten obtener evidencia y verificar la consistencia de los controles existentes y también medir el riesgo por deficiencia de estos o por su ausencia.

- Se diseñan y planifican para asegurar que los controles se diseñan adecuadamente y funcionan de forma efectiva y continuada.

Pruebas de cumplimiento

- Permiten determinar si un control se está realizando de la forma prevista en las normas y políticas de seguridad establecidas por el organismo responsable del sistema.
- Su objetivo principal es determinar si el control se realiza y si sus resultados son efectivos.
- Se deben realizar siempre.

Pruebas sustantivas

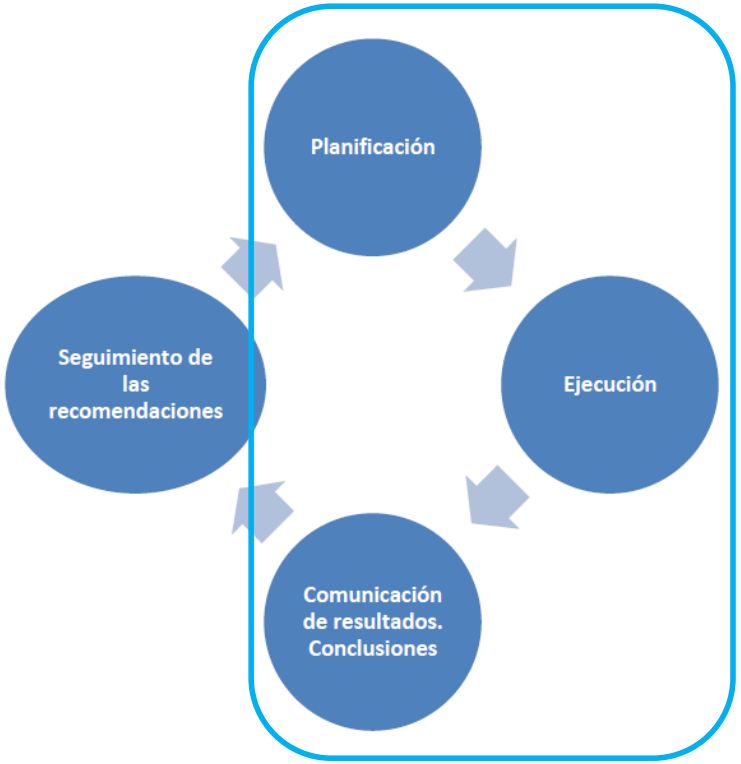
- Permiten confirmar la exactitud de determinadas situaciones o hechos, pero fundamentalmente permiten sustanciar el impacto y alcance de una deficiencia, o incidencia de seguridad, con proyección sobre la integridad de determinada información o de un proceso.
- Sólo se realizan si fallan las pruebas de cumplimiento o si no existe el control correspondiente.

Ejemplo: en la revisión de un inventario de copias de respaldo, una prueba de cumplimiento puede determinar si los controles previstos se están cumpliendo o no, pero con una prueba sustantiva, se podría determinar cuántos, y /o cuáles elementos no están incluidos en el inventario.

Fuente: Glosario Guía CCN-STIC 802: ENS. Guía de auditoría.

Normalmente se habla de 3 fases:

1. **Planificación**/Planeamiento/Planeación/Toma de contacto.
2. **Ejecución**/Desarrollo/Actuación.
3. **Informe**/Conclusiones/Comunicación de resultados.



Aunque a veces se pueda hablar de una cuarta etapa:

4. Seguimiento de las recomendaciones.

- Objetivo: preparar todo el proceso de auditoría y **recopilar información general** de la organización auditada, su actividad y sus sistemas:
  - Pero **no** se recopilan evidencias, ni se realizan pruebas, ni se entrevista a usuarios.

- Como toda planificación, se trata de determinar:

  - Objetivos de la auditoría.

  - Alcance: límites del ámbito funcional o incluso territorial. Procesos, actuaciones, sistemas que se van a auditar.

  - **Metodología**:
    - Procedimientos de auditoría a seguir: tanto de recogida de datos (muestras, entrevistas) como de análisis.
    - Pruebas a ejecutar.
    - Documentos, instrumentos y herramientas que se van a utilizar.

- Y por último, como toda planificación:
  - Cronograma detallando:
    - Actividades y tareas a desarrollar: agenda de reuniones, entrevistas, revisiones.
    - Recursos humanos y técnicos.
- Esta fase se plasma en un documento que puede denominarse:
  - **Plan de auditoria**: descripción de las actividades y de los detalles acordados de una auditoría [ISO 19011]. También denominado Plan de trabajo o Guion de auditoria.
  - **Programa de auditoría**: acuerdos para un conjunto de una o más auditorías planificadas para un periodo de tiempo determinado y dirigidas hacia un propósito específico [ISO 19011].

2. Ejecución

Antes del inicio de la ejecución suele realizarse la formalización del inicio de la actuación (reunión de apertura o kick-off meeting):

- Notificación o reunión entre responsables del equipo auditor y unidad auditada.
- Designación de interlocutores.

Objetivo: realizar actuaciones y trabajos de campo para **obtener evidencias** y **hallazgos** suficientes y adecuados que ayuden a cumplir los objetivos de la auditoría.

Evidencia de auditoría (Guía 802):

- Registros, declaraciones de hechos o cualquier otra información que es pertinente para los hallazgos de auditoría y que es verificable. La evidencia de auditoría puede ser cualitativa o cuantitativa.

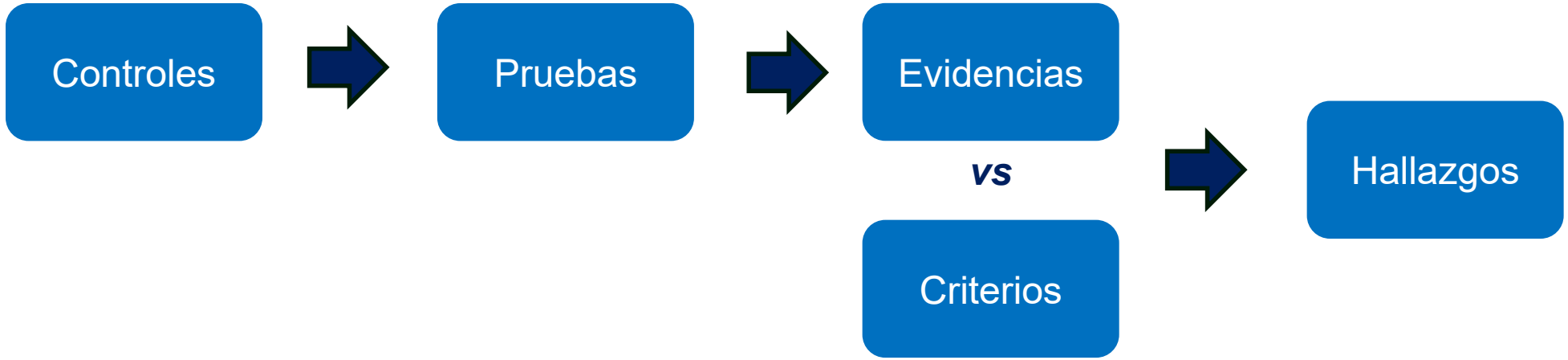
- Las evidencias consisten, principalmente, en las demostraciones y testimonios (documentales, automatizadas, etc.) de los resultados de la aplicación de los procedimientos de auditoría (pruebas). Éstas deben ser suficientes para soportar las conclusiones del auditor. Para ello deben acreditar determinadas situaciones o hechos objetivos en cuanto a los hechos a los que se refieren. La evaluación de estas evidencias corresponde al auditor para documentar su hallazgo.

Hallazgos de auditoría (Guía 802):

- Resultados de la evaluación de la evidencia de auditoría frente a los criterios de auditoría.
- Los hallazgos de auditoría pueden indicar conformidad o no conformidad.
- Si los requisitos de auditoría se seleccionan de entre los requisitos legales u otros requisitos, el hallazgo de auditoría se denomina "cumplimiento" o "no cumplimiento".

Criterio de auditoría (Guía 802):

- Conjunto de políticas, procedimientos o requisitos usados como referencia frente al cuál se compara la evidencia de auditoría.



- **Inspección**: revisión de documentación técnica, organizativa, estándares y procedimientos.
- **Observación**: ver la ejecución de un proceso o procedimiento ejecutado por el personal de la entidad. También cubre las evidencias físicas que han de documentarse.
- **Entrevistas**: preguntas por escrito (formularios) o mediante entrevistas:
  - Preparadas con antelación y documentadas.
  - Cuestionarios y listas de verificación (checklists) como material de apoyo.
  - Tipos: preliminares de alto nivel, de detalle con personal técnico o de seguimiento.
- **Confirmaciones**: corroboraciones, normalmente por escrito y a terceros, de una información.
- **Cálculos**: comprobaciones de informaciones numéricas. Simulaciones.
- **Procedimientos analíticos**: comparación entre la información esperada y la registrada, evaluación de interrelaciones de elementos, benchmarking y estadísticas, etc.

3. Informe

- Objetivo: analizar toda la información (evidencias y hallazgos), **elaborar** un **informe** y comunicar las conclusiones.

- Principales hitos:
  - Reunión de cierre: comunicando fin de la ejecución y cambio de fase.
  - Preparación y distribución del borrador del informe.
  - Procedimiento de tramitación / periodo de respuesta: observaciones y alegaciones de la entidad auditada al borrador.
  - Preparación y distribución del informe definitivo.

- El informe debe ser claro y conciso. Se suele acompañar de anexos con información más completa y detallada.

- Según la Instrucción Técnica de Seguridad de Auditoría de la Seguridad de los Sistemas de Información (ITS de Auditoría del ENS), el informe de auditoría deberá contener la información adecuada y suficiente para facilitar y justificar la **decisión de certificación**, como mínimo:

  - Las áreas organizativas, módulos o funciones del sistema de información cubiertas por la auditoría.

  - Los hallazgos identificados, tanto de conformidad como de no conformidad, incluyendo las Observaciones.

  - Los detalles de las no conformidades identificadas se justificarán mediante evidencias objetivas y su correspondencia con los requisitos del ENS.

  - La categoría del sistema, con detalle del nivel de seguridad en cada una de las dimensiones.

  - La **conclusión** o **dictamen** del Equipo de Auditoría sobre si el sistema de información debe ser certificado o no, con información que soporte esa conclusión.

Perfil del auditor

- Principios del auditor público según el código ético para la auditoría pública de la IGAE:
  - Integridad, independencia, objetividad, competencia profesional y diligencia debida, confidencialidad, comportamiento profesional, escepticismo profesional.

- Código de ética profesional de miembros y portadores de certificaciones ISACA (Information Systems Audit and Control Association):
  - Principios muy similares: cumplimiento normativo, objetividad, diligencia, celo profesional, competencia, confidencialidad, etc.
  - Certificaciones: CISA (auditores SSII), CISM (seguridad de la información), CGEIT (gobierno empresarial IT), CRISC (riesgos y sistemas de control), AAIA (IA), etc.

- Equipo auditor ENS en la Guía de auditoría ENS CCN-STIC 802.



Equipo auditor ENS (Guía 802)

- Quienes constituyen el equipo auditor deben disponer de la competencia y la imparcialidad necesaria para que el informe de auditoría que emitan sea confiable [37].

Equipo auditor externo a la organización (auditoría de certificación de conformidad)

- El equipo auditor de un organismo de certificación, ya sea este una EC o un OAT, deberá estar compuesto por profesionales (**Auditor Jefe**, posibles **auditores** y, en su caso, **expertos técnicos**) que garanticen que se dispone de los conocimientos suficientes para asegurar la adecuada y ajustada realización de la auditoría [44].

Equipo auditor interno de la organización (auditoría interna de verificación)

- En las auditorías internas de verificación, si el equipo auditor es interno, deberá procurarse que sea independiente de los sistemas de información o servicios que sean objeto de la auditoría. Por ejemplo, perteneciendo a otra área o departamento, de modo que se asegure su independencia y objetividad [47].

Equipo auditor ENS (Guía 802)

Anexo A. Requisitos para el equipo auditor

- Los requisitos del equipo auditor diferirán según se trate de una auditoría de cumplimiento orientada a la Certificación de Conformidad con el ENS, o de una auditoría interna de verificación [136].

Requisitos para un organismo de certificación

- [138] El **Auditor Jefe** debe estar en condiciones de demostrar, al menos:
  - Formación en auditorías de sistemas de información, a través de certificaciones reconocidas, cursos, seminarios o actividades formativas regladas o impartidas por entidades reconocidas, de calidad y adecuado número de horas formativas que permitan evidenciar la idoneidad y suficiencia de los conocimientos adquiridos.
  - Experiencia verificable de, al menos, 4 años, en la realización de auditorías de TI.
  - Conocimiento de seguridad y gestión de riesgos de seguridad, demostrable por medio de certificaciones o experiencia de, al menos, 4 años en estas competencias.
  - Conocimiento de los requisitos del ENS, demostrable por medio de cursos o seminarios sobre estas competencias, de calidad y alcance suficientes, que comprendan un mínimo de 20 horas de formación.
  - Conocimientos de otra legislación aplicable (LOPD, ENI, identidad y firma-e, entre otras).

Equipo auditor ENS (Guía 802)

- [139] El resto del equipo auditor:
  - No es necesario que posea las competencias exigidas para el Auditor Jefe, aunque debe contar con formación suficiente, tanto en seguridad como en auditoría de los sistemas de información, en función de las responsabilidades que le sean asignadas en cada auditoría.
  - No obstante, deberán estar familiarizados con las Guías CCN-STIC aplicables a cada caso, y disponer de conocimientos en la administración de seguridad de sistemas operativos y aplicaciones, así como en infraestructuras de redes informáticas y mecanismos criptográficos, tratándose el ENS de un marco o "framework" de seguridad.

Requisitos para quienes realizan auditorías internas

- [140] En relación a las auditorías internas de verificación, especialmente cuando éstas se externalizan, la organización auditada deberá verificar que se le evidencie la competencia del Auditor Jefe, por ejemplo:
  - Mediante la aportación de su CV y la relación de auditorías equivalentes en las que ha participado.
  - Deberá disponer y acreditar buenos conocimientos sobre el ENS, sobre seguridad sistemas, sobre protección de datos, etc.

- [141] Si el Auditor Jefe se apoya en otros miembros del equipo auditor (otros auditores o expertos técnicos), también estos deberán evidenciar su competencia y experiencia en el área de responsabilidad que le haya sido asignada.

Normas y estándares de auditoría en el ámbito nacional

- Auditoría en materia de protección de datos personales:
  - Reglamento General de Protección de datos 679/2016
  - Ley orgánica 3/2018 de protección de datos personales y garantía de derechos digitales

- Auditoría de seguridad:
  - Esquema Nacional de Seguridad, RD 311/2022
  - Instrucción Técnica de Seguridad – Auditoría de la seguridad de los sistemas de información
  - Guías CCN-STIC. Serie 800. ENS

- En la normativa anterior (LOPD 15/1999 y RD 1720/2007) quedaba claro que sí había que hacer una auditoría al menos cada 2 años para los sistemas con datos personales de al menos nivel medio.

- En cambio, en el **marco normativo actual** (RGPD y LOPD 3/2018) **no se establece esta obligación de auditoría de protección de datos personales**.

- De todas formas, aún no siendo obligatorio:
  - Nada impide que se realicen auditorías de forma voluntaria.
  - Varios artículos especifican detalles de las mismas en caso de realizarse.

Artículo 32: Seguridad del tratamiento

1. Teniendo en cuenta el estado de la técnica, los costes de aplicación y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:
   a) la seudonimización y el cifrado de datos personales
   b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento
   c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico

   d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.

¿No es esto una auditoría?

- Artículo 28: el encargado del tratamiento pondrá a disposición del responsable toda la información necesaria para permitir y contribuir a la realización de auditorías, incluidas inspecciones, por parte del responsable o de otro auditor autorizado por dicho responsable.

- Artículo 39: El DPD supervisará el cumplimiento del Reglamento, incluida la asignación de responsabilidades, la concienciación y formación del personal que participa en las operaciones de tratamiento, y las auditorías correspondientes.

- Artículo 47: La autoridad de control competente aprobará normas corporativas vinculantes que especificarán mecanismos de verificación de cumplimiento como auditorías de protección de datos.

- Artículo 58: Cada autoridad de control podrá llevar a cabo investigaciones en forma de auditorías de protección de datos.



102. ¿Cuál es el plazo que establece el RGPD (Reglamento General de Protección de Datos), (UE) 2016/679, como obligación para la realización de una auditoría de protección de datos?:

a) Cada 2 años de forma general, al realizar una evaluación de conformidad.

b) Cada año para los sistemas de alto riesgo que requieran EIPD (Evaluación de Impacto de Protección de Datos), cada dos años para el resto.

c) No establece un plazo. La Autoridad de Control determina cuándo realizar auditorías de protección de datos.

d) Cada vez que se realice un cambio significativo en el perfil de riesgo del sistema.

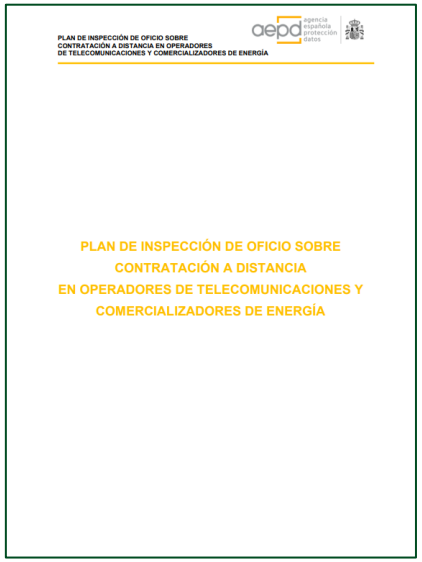
Pregunta A1, OEP 2022, convocatoria extraordinaria

Artículo 54. Planes de auditoría

1. La Presidencia de la AEPD podrá acordar la realización de planes de auditoría preventiva, referidos a los tratamientos de un sector concreto de actividad.

2. A resultas de dichos planes, la Presidencia de la AEPD podrá dictar las directrices, generales o específicas, para asegurar la plena adaptación del sector o responsable al RGPD y a la presente ley orgánica.

3. Las directrices serán de obligado cumplimiento para el sector o responsable al que se refiera el plan de auditoría.





Real Decreto 311/2022 por el que se regula el Esquema Nacional de Seguridad

Artículo 31. Auditoría de la seguridad:

1. Los sistemas de información comprendidos en el ámbito de aplicación de este real decreto serán objeto de una **auditoría regular ordinaria**, al menos cada **dos años**, que verifique el cumplimiento de los requerimientos del ENS.

   Con carácter extraordinario, deberá realizarse dicha auditoría siempre que se produzcan modificaciones sustanciales en los sistemas de información, que puedan repercutir en las medidas de seguridad requeridas.

   El plazo de dos años señalado en los párrafos anteriores podrá extenderse durante tres meses cuando concurran impedimentos de fuerza mayor no imputables a la entidad titular del sistema de información.

2. La auditoría se realizará en función de la **categoría del sistema** y, en su caso, del perfil de cumplimiento específico que corresponda, según lo dispuesto en los anexos I y III y de conformidad con lo regulado en la Instrucción Técnica de Seguridad de Auditoría de la Seguridad de los Sistemas de Información (ITS Auditoría).

3. En la realización de las auditorías de la seguridad se utilizarán los criterios, métodos de trabajo y de conducta generalmente reconocidos, así como la normalización nacional e internacional aplicables a este tipo de actividades.

4. El informe de auditoría deberá dictaminar sobre el grado de cumplimiento de este real decreto identificando los hallazgos de cumplimiento e incumplimiento detectados.

5. Los informes de auditoría serán presentados al responsable del sistema y al responsable de la seguridad. El responsable de seguridad presentará sus conclusiones al responsable del sistema para que éste adopte las medidas correctoras adecuadas.

6. En el caso de los sistemas de categoría ALTA, visto el dictamen de auditoría y atendiendo a una eventual gravedad de las deficiencias encontradas, el responsable del sistema podrá suspender temporalmente el tratamiento de informaciones, la prestación de servicios o la total operación del sistema, hasta su adecuada subsanación o mitigación.

7. Los informes de auditoría podrán ser requeridos por los responsables de cada organización, con competencias sobre seguridad de las tecnologías de la información, y por el CCN.

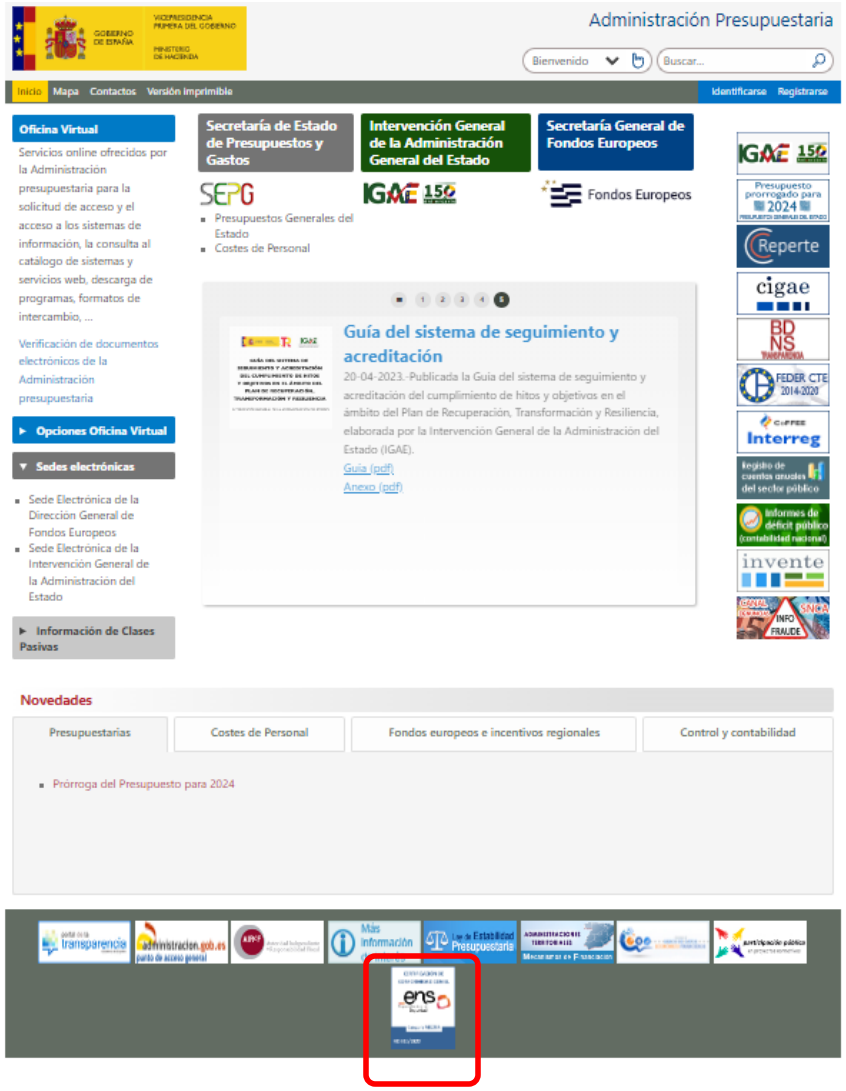
Artículo 38. Procedimientos de determinación de la conformidad con el ENS

1. Los sistemas de información serán objeto de un proceso para determinar su conformidad con el ENS. A tal efecto, los sistemas de categoría MEDIA o ALTA precisarán de una auditoría para la **certificación** de su conformidad, sin perjuicio de la auditoría de la seguridad prevista en el artículo 31 que podrá servir asimismo para los fines de la certificación, mientras que los sistemas de categoría BÁSICA solo requerirán de una autoevaluación para su **declaración** de la conformidad, sin perjuicio de que se puedan someter igualmente a una auditoria de certificación.

2. Tanto el procedimiento de autoevaluación como la auditoría de certificación se realizarán según lo dispuesto en el artículo 31 y el anexo III y en los términos que se determinen en la correspondiente ITS, que concretará asimismo los requisitos exigibles a las entidades certificadoras.

3. Los sujetos responsables de los sistemas de información darán publicidad, en los correspondientes portales de internet o sedes electrónicas a las declaraciones y certificaciones de conformidad con el ENS, atendiendo a lo dispuesto en la mencionada ITS.

Por ejemplo, en el Portal de la Administración Presupuestaria de la IGAE:





Anexo III. Auditoría de la seguridad

1. *Objeto de la auditoría*

- La seguridad de los sistemas de una organización será auditada en los siguientes términos, al objeto de constatar:

a) Que la política de seguridad define los roles y funciones de los responsables del sistema, la información, los servicios y la seguridad del sistema.

b) Que existen procedimientos para la resolución de conflictos entre dichos responsables.

c) Que se han designado personas para dichos roles a la luz del principio de «diferenciación de responsabilidades».

d) Que se ha realizado un análisis de riesgos, con revisión y aprobación anual.

e) Que se cumplen las recomendaciones de protección descritas en el anexo II, sobre Medidas de Seguridad.

f) Que existe un sistema de gestión de la seguridad de la información, documentado y con un proceso regular de aprobación por la Dirección.

Anexo III. Auditoría de la seguridad

- La auditoría se basará en la existencia de evidencias que permitan sustentar objetivamente el cumplimiento del ENS.

- En concreto, se considerará evidencia suficiente el empleo de productos certificados, conforme al artículo 19 de «adquisición de productos de seguridad y contratación de servicios de seguridad».

- Se dispondrá de un programa o plan de auditorías documentado.

2. *Niveles de auditoría*

   - Auditoría a sistemas de categoría BÁSICA: no necesitarán realizar una auditoría. Bastará una autoevaluación realizada por el mismo personal que administra el sistema de información o en quien éste delegue.

   - Auditoría a sistemas de categoría MEDIA o ALTA: el informe de auditoría dictaminará sobre el grado de cumplimiento de este RD identificando los hallazgos de conformidad y no conformidad.

Disposición adicional segunda. Desarrollo del Esquema Nacional de Seguridad

- En desarrollo de lo dispuesto en este real decreto, la persona titular del Ministerio para la Transformación Digital y de la Función Pública (MTDFP), a propuesta de la Comisión Sectorial de Administración Electrónica (CSAE) y a iniciativa del Centro Criptológico Nacional (CCN), aprobará las Instrucciones Técnicas de Seguridad (ITS) de obligado cumplimiento, que se publicarán mediante Resolución de la persona titular de la Secretaría de Estado de Función Pública (SEFP).

- Para el mejor cumplimiento de lo establecido en este real decreto, el CCN, en el ejercicio de sus competencias, elaborará y difundirá las correspondientes guías de seguridad de las tecnologías de la información y la comunicación (guías CCN-STIC), particularmente de la serie 800, que se incorporarán al conjunto documental utilizado para la realización de las auditorías de seguridad.

ens
Esquema Nacional de Seguridad

ITS – Instrucción Técnica de Seguridad

Resolución de 27 de marzo de 2018, de la Secretaría de Estado de Función Pública, por la que se aprueba la Instrucción Técnica de Seguridad de Auditoría de la Seguridad de los Sistemas de Información.

- El propósito de la auditoría de seguridad, además de determinar el grado de conformidad del sistema con el ENS es, en su caso, posibilitar la obtención de la correspondiente:
  - Declaración de conformidad para sistema de categoría BÁSICA: sólo autoevaluación.
  - Certificación de conformidad para sistemas de categoría MEDIA y ALTA (opcional para BÁSICA).

- Guías referenciadas:
  - CCN-STIC 802 Guía de auditorías de cumplimiento
  - CCN-STIC 804 Guía de implantación
  - CCN-STIC 808 Verificación del cumplimiento de las medidas en el ENS

- Para asegurar la independencia objetiva de la Entidad Certificadora, las tareas de auditoría no incluirán en ningún caso la ejecución de acciones que puedan ser consideradas actividades de consultoría o similares, tales como implantación o modificación del sistema auditado, redacción de documentos requeridos, así como recomendaciones particulares sobre productos o soluciones concretas, entre otros.

- El Equipo Auditor está obligado a requerir y obtener las evidencias pertinentes para verificar los criterios de auditoría, cuya evaluación constituirán los hallazgos en que se basarán las conclusiones recogidas en el Informe de Auditoría.

- Los hallazgos de no conformidad se clasificarán en:
  - No Conformidad Mayor
  - No Conformidad Menor
  - Observación



- El dictamen final de la Auditoría de la Seguridad será uno de los tres siguientes:

  - **FAVORABLE**: cuando no se evidencie ninguna «No Conformidad Mayor» o «No Conformidad Menor».

  - **FAVORABLE CON NO CONFORMIDADES**: cuando se evidencie cualquier no conformidad, mayor o menor. En este caso, la entidad responsable del sistema deberá presentar, en el plazo máximo de un mes, un Plan de Acciones Correctivas sobre tales hallazgos de no conformidad a la entidad certificadora para su evaluación.

  - **DESFAVORABLE**: Cuando, por el número o la transcendencia de las no conformidades detectadas, no sea posible decidir sobre su resolución a través de un Plan de Acciones Correctivas. En este caso se requerirá la realización de una auditoría extraordinaria que verifique la adopción de las medidas correctoras adecuadas.

- La certificación de conformidad con el ENS únicamente podrá expedirse si el dictamen fuera «FAVORABLE» o, si habiendo sido «FAVORABLE CON NO CONFORMIDADES», el Plan de Acciones Correctivas presentado trata y resuelve los hallazgos de no conformidad evidenciados, a criterio de la entidad certificadora.

- Ante un dictamen «DESFAVORABLE», la entidad titular del sistema de información auditado, en un plazo no superior a **seis meses** desde la fecha de emisión del Informe de Auditoría, deberá someterse a una Auditoría Extraordinaria, exclusivamente sobre los hallazgos de no conformidad evidenciados que, de resultar satisfactorio, permitirá la expedición del correspondiente Certificado de Conformidad con el ENS.

- En caso de un sistema ya certificado sobre el que se detecten No Conformidades Mayores, durante el período de resolución de las mismas el **certificado** de conformidad quedará en **suspenso**. En caso de no cerrar las No Conformidades Mayores en un plazo de seis meses el Certificado de Conformidad quedaría revocado y la entidad auditada deberá eliminar el Distintivo de Conformidad de su sede hasta su próxima recertificación.

- Guías CCN-STIC: **Serie 800**: centrada en el **ENS**.

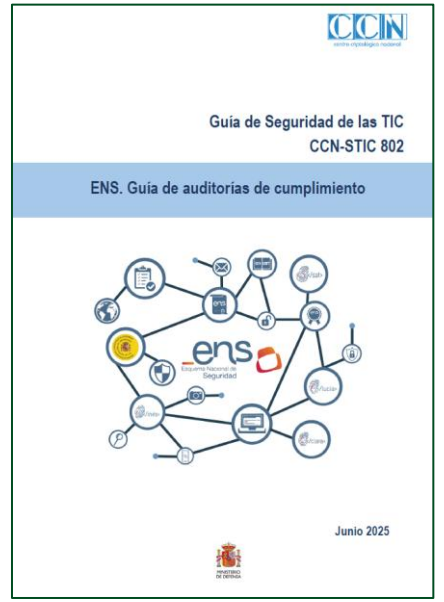
  - **802: Auditoría**: requisitos del equipo de auditoría, cómo obtener evidencias, documentar hallazgos, redactar informe, etc.

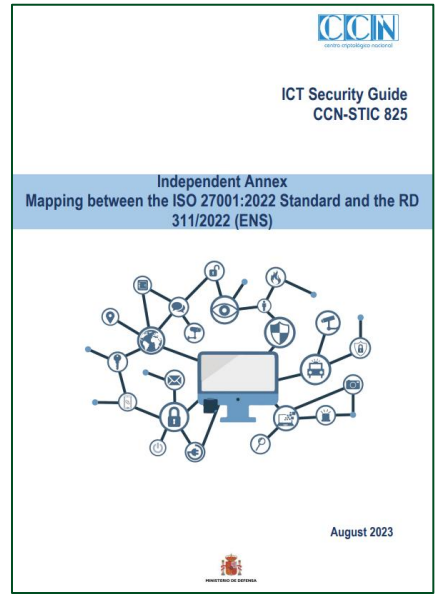
  - 804: Guía de implantación: pautas de carácter general, para que los responsables de los sistemas puedan implantar rápida y efectivamente las medidas de seguridad requeridas.

  - 808: Verificación cumplimiento: complementa a las anteriores, sirviendo de herramienta de trabajo de campo, tipo checklist, con espacios reservados para anotaciones.

  - 809: Declaración y certificación de conformidad

  - 825: ENS y Certificaciones 27001





Otras guías CCN menos conocidas:

- Guía de auditoría de cumplimiento del **ENI**: conjunto de controles agrupados en marco organizativo, marco operacional y medidas técnicas.

- Guía de seguridad CCN-STIC IC-01/19: Criterios generales de auditoría y certificación.

- Guía de seguridad CCN-STIC 122: Procedimiento de Reconocimiento y Requisitos del **Órgano de Auditoría Técnica** (**OAT**) del ENS.
  - Define el procedimiento utilizado por el CCN para el reconocimiento de la capacidad técnica y la imparcialidad y ausencia de conflicto de intereses de entidades públicas para la realización de auditorías de conformidad en el ENS y expedir los correspondientes certificados.
  - Por tanto, la auditoría ENS la puede hacer una Entidad de Certificación (EC) externa o un OAT interno.

- Guía de Seguridad CCN-STIC CCN-CERT IC-02/20: Guía para la contratación de auditorías de certificación del ENS.
  - Contrato de servicios (abierto, negociado, restringido o menor), tiempos de la auditoría, EC acreditada, etc.

Guía CCN-STIC 802: ENS. Guía de auditorías de cumplimiento

- Distingue entre:
  - Auditoría de cumplimiento o de certificación de conformidad con una norma (ENS o incluso ISO) realizada por:
    - Una Entidad de Certificación (EC) del sector privado, acreditada por ENAC.
    - Un Órgano de Auditoría Técnica (OAT) del sector público, reconocido por el CCN.
    - En ocasiones excepcionales, el propio CCN [14].
  - Auditoría interna de verificación: más técnica y acotada a determinadas medidas (ej. “pentesting”).
  - Auditorías extraordinarias: por modificaciones, por incremento de categoría o por incremento de alcance.
- Sobre el equipo auditor: requisitos del Jefe Auditor, Auditores y Expertos Técnicos (ya comentados).

Guía CCN-STIC 808: Verificación del cumplimiento

- El principal objetivo de esta guía es servir de itinerario de auditoría para la evaluación de la conformación con el ENS.

- Pretende ser una ayuda para el trabajo de campo de los auditores, pudiendo ser adaptada y empleada directamente como checklist, sin perjuicio de emplear un asistente de autoevaluación/certificación que se materialice en una solución automatizada (AMPARO).

Art.40 y 41	Categorización de los sistemas de información		
	Medida aplica: SI ☐ NO ☐ **Medida auditada**: SI ☐ NO ☐		
Propuesta de evidencias			
	☐ Documento de valoración de servicios e información ☐ Documento formal en el que los responsables de los servicios y de la información suscriben las valoraciones. ☐ Documento formal en el que el Responsable de Seguridad categoriza el sistema.		
	Aspectos a evaluar	**Hallazgos del auditor / referencia a las evidencias**	**Cumple**
Art. 40	¿Los responsables de la información y los responsables de los servicios han valorado los activos esenciales que son de su competencia en las cinco dimensiones de la seguridad?		☐ SI ☐ NO
Art. 41	¿Se dispone de un documento formal que recoja dichas valoraciones y evidencia de la conformidad respecto a las mismas de los responsables de la información y los servicios afectados? ¿Se han tenido en cuenta todos los aspectos identificados en el anexo I como punto de entrada para realizar la valoración?		☐ SI ☐ NO
Art. 41	¿El Responsable de Seguridad determina la categoría del sistema mediante un documento formal, en base a las valoraciones de servicios e información soportados por el sistema de información que han realizado sus responsables? ¿En caso de que haya diferentes responsables de seguridad se ha realizado un comité para tomar en cuenta las decisiones de todos ellos?		☐ SI ☐ NO

Op.exp.8	Registro de la actividad		
Categoría / dimensión T	**Medida aplica**: SI ☐ NO ☐ **Medida auditada**: SI ☐ NO ☐ **Grado de implementación**: SI ☐ EN PROCESO ☐ NO ☐ **Medida compensatoria**: SI ☐ NO ☐ **Medida complementaria de vigilancia**: SI ☐ NO ☐		
Propuesta de evidencias			
	☐ Evidencia de los registros de actividad conservados. ☐ Evidencia de configuración de los registros de actividad (LOGS) en los servidores.		
	☐ Evidencia de revisión de los registros de actividad centralizados. ☐ Evidencia de servidores NTP o equivalentes. ☐ Documentación de seguridad del sistema sobre gestión de registros de actividad. ☐ Evidencia de protección del acceso a los registros de actividad		
	☐ Evidencia de herramientas de análisis de LOGS. ☐ Evidencia de sistemas automáticos de recolección de registros y correlación de eventos (tipo SIEM).		
	Aspectos a evaluar	**Hallazgos del auditor / referencia a las evidencias**	**Cumple**

Guía CCN-STIC 809: Declaración, Certificación y Aprobación Provisional de conformidad con el ENS. Distintivos de cumplimiento













- Esta guía da recomendaciones para cumplir con artículo 38.2 ENS de dar publicidad en sede o portales a las declaraciones o certificaciones de conformidad.

- Declaración de conformidad:
  - Categoría BÁSICA
  - Autoevaluación

- Certificación de conformidad:
  - Categorías MEDIA y ALTA obligatorio, BÁSICA opcional
  - Auditoría formal

Guía CCN-STIC 809

- El CCN mantendrá en su sede-e una relación actualizada de las Entidades de Certificación (EC), acreditadas o en vías de acreditación, para expedir Certificaciones de Conformidad con el ENS.

- Introduce el concepto de Aprobación Provisional de Conformidad (APC):
  - Podrá expedirse excepcionalmente para sistemas de categorías BÁSICA o MEDIA.
  - Será **emitida por el CCN**, a petición de la EC/OAT.
  - Deberán concurrir, simultáneamente, los siguientes requisitos (guía CCN-CERT IC-01/19).
    - Persiga la emisión del primer Certificado de Conformidad del sistema de información auditado.
    - El Plan de Acciones Correctivas, por razones adecuadas y razonables, requiere un período de ejecución superior a 3 meses.
    - No podrá ser aplicado cuando se hayan detectado No Conformidades Mayores.
  - Tendrán una vigencia de 6 meses, que podrá ser ampliado por otros 6 meses motivadamente.

- Crea el Consejo de Certificación del ENS (CoCENS).

Guía CCN-STIC 825: ENS y Certificaciones 27001

- Muestra las medidas compatibles entre el ENS con el estándar ISO/ IEC 27001:2022.
- Dicha compatibilidad no debe ser interpretada como una relación aritmética de equivalencia "estricta", sino una interpretación bajo un análisis general de los contenidos de ambas normas.
- Esta guía solo es una aproximación general que deben ser particularizada para cada organización.

Cod.	Control	ISO/IEC 27001:2022[40]	Nivel compatible control ISO 27001:2022 - RD 311/2022.	
		[Control Principal]	Categoría ENS	Nivel compatible
op.pl.1	Análisis de riesgos	6.1 – Acciones para tratar los riesgos y oportunidades	ALTA *	
op.pl.2	Arquitectura de seguridad	Clausula 4.4 Sistema de gestión de la seguridad de la información 8.27 Arquitectura segura de sistemas y principios de ingeniería	MEDIA (+R2*)	
op.pl.3	Adquisición de nuevos componentes	5.8 Seguridad de la información en la gestión de proyectos	MEDIA	
op.pl.4	Dimensionamiento/ Gestión de capacidades	8.6 Gestión de capacidades	MEDIA	
op.pl.5	Componentes certificados	Nivel de medidas compatibles: No se contempla expresamente	MEDIA	

Identificación	Nivel Compatible	Detalle
	Análogo	En el análisis de requisitos del control analizado, se ha concluido que existe plena compatibilidad. Ambas normas exigen idénticos requisitos o las medidas detalladas resultan asimilables. Las finalidades de seguridad para el control analizado son análogos en ambas normas.
	Parcialmente análogo	En el análisis de requisitos del control analizado, se ha concluido que no existe plena compatibilidad. Las normas no son igual de exigentes en los requisitos descritos. Parte de los requisitos del control analizado resulta análogo, pero no pueden considerarse cubiertos todos los extremos del control. Puede ser necesario complementar el control con otros controles diseminados por la norma, o bien es posible que la norma no haya considerado los requisitos del control no cubiertos. Si bien la finalidad puede ser similar, una de las normas es más exigente y su finalidad resulta más extensa.
	Nula	En el análisis de requisitos del control analizado, se ha concluido que no existe compatibilidad. Alguna de las normas no considera el control analizado. Una de las normas ha desplegado un control con una finalidad que no es perseguida por la otra norma.

Guía CCN-CERT IC-01/19. ENS: Criterios Generales de Auditoría y Certificación

- Objeto: servir de referencia y establecer los criterios generales para la auditoría y certificación, algunos a modo de ejemplo:
  - Las certificaciones de servicios en la nube expresarán la ubicación (ciudad, región y país) de los CPD en los que se soportan dichos servicios.
  - La experiencia ha evidenciado que unos tiempos de auditoría razonables atenderían al siguiente criterio:
    - Fase de estudio documental previo: mínimo entre 0,5 y 1 jornada.
    - Fase de auditoría: mínimo 1,5 / 2,5 / 3,5 jornadas, según categoría BÁSICA / MEDIA / ALTA.
    - Fase de redacción de informes: mínimo 1 jornada.
  - El CCN se reserva el derecho de acompañar a las EC en todas aquellas auditorías que estas realicen.
  - Auditoría en modo remoto: están permitidas y podrán complementarse con inspecciones “in situ”.

Estándares internacionales de referencia

- Estándares internacionales ISO:
  - ISO 27000: Sistema de Gestión de la Seguridad de la Información.
  - ISO 15408: Criterios de evaluación para la seguridad de TI (Common Criteria).
  - ISO 19011: Directrices para la auditoría de los sistemas de gestión.
  - ISO 17000: Evaluación de la conformidad.
- Otros marcos de referencia internacionales:
  - COBIT 2019: Control Objectives for Information Technologies.

UNE-EN ISO/IEC 27000:2021: Visión de conjunto y vocabulario para un SGSI.

UNE-EN ISO/IEC 27001:2023: Requisitos de un SGSI.

- Norma principal y certificable.
- Tiene un anexo que resume los controles de la 27002.

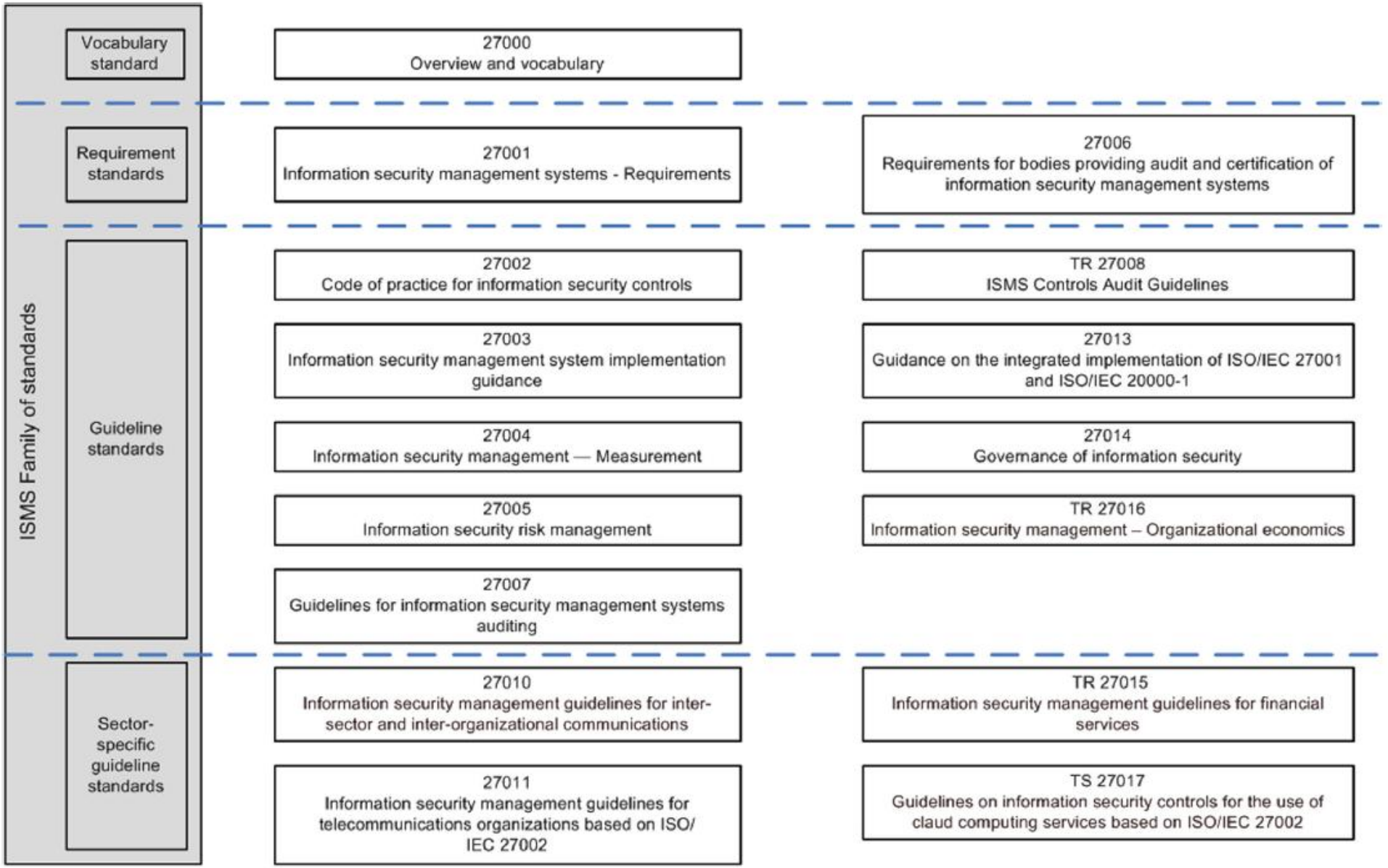
UNE-EN ISO/IEC 27002:2023: Controles de seguridad de la información.

- Estructura simplificada de versiones anteriores. Enfoque más integral y holístico del SGSI.
- 93 controles organizados en 4 cláusulas:
  - Controles organizativos
  - Controles de personas
  - Controles físicos
  - Controles tecnológicos
- No certificable.

Noticia AENOR

UNE-EN ISO/IEC 27005: Guía para la gestión de riesgos de seguridad de la información.
UNE-EN ISO/IEC 27006: Requisitos para organismos que realizan auditorías y certificación de SGSI.
UNE-EN ISO/IEC 27007: Directrices para la auditoría de los SGSI.

Familia ISO 27000



Criterios de evaluación para la seguridad de TI (Common Criteria, CC)

- Serie de normas que establecen unos **criterios comunes** de **evaluación de la seguridad** de las TIC, para que el resultado del proceso de evaluación sea aceptado en múltiples países.

- Partes de la serie:
  - ISO 15408-1: Parte 1: Introducción y modelo general
  - ISO 15408-2: Parte 2: Componentes funcionales de seguridad
  - ISO 15408-3: Parte 3: Componentes de aseguramiento de la seguridad



- El objeto de la evaluación se denomina TOE, Target of Evaluation.

- Establece 7 niveles de evaluación (EAL: Evaluation Assurance Level), desde EAL1 (el más simple) al EAL7 (verificación más exhaustiva). Ej: el chip de DNIe tiene certificado EAL5+.

- En España es el CCN, como Organismo de Certificación del Esquema Nacional de Evaluación y Certificación de la Seguridad de las Tecnologías de la Información (OC-CCN), quien certifica la seguridad de los productos y sistemas usando, entre otros, estos Common Criteria.

Criterios de evaluación para la seguridad de TI (Common Criteria)

- Catálogo de Productos y Servicios certificados por el CCN: firewalls, cifradores, antivirus, proxies, routers, móviles, etc.
  - Por ejemplo, en el catálogo hay varios HSM con EAL4+.
  - Recordamos, en la auditoría ENS se considerará **evidencia suficiente** el empleo de **productos certificados** por el CCN (artículo 19 y Anexo III de auditoría 1.2.d)
  - El Catálogo, además de su portal específico, se ofrece en la Guía CCN-STIC 105.



Common criteria LINCE

En la actualidad, se utilizan principalmente dos metodologías de certificación.

Directrices para la auditoría de los sistemas de gestión

- Principios de auditoría:
  - Integridad, objetividad, profesionalidad, confidencialidad, independencia, enfoque basado en evidencias.

- Términos y definiciones: única parte pública a través de ISO OBP.

- Gestión de un programa de auditorías:
  - Objetivos, nº auditorías, riesgos, roles, recursos, métodos, etc.

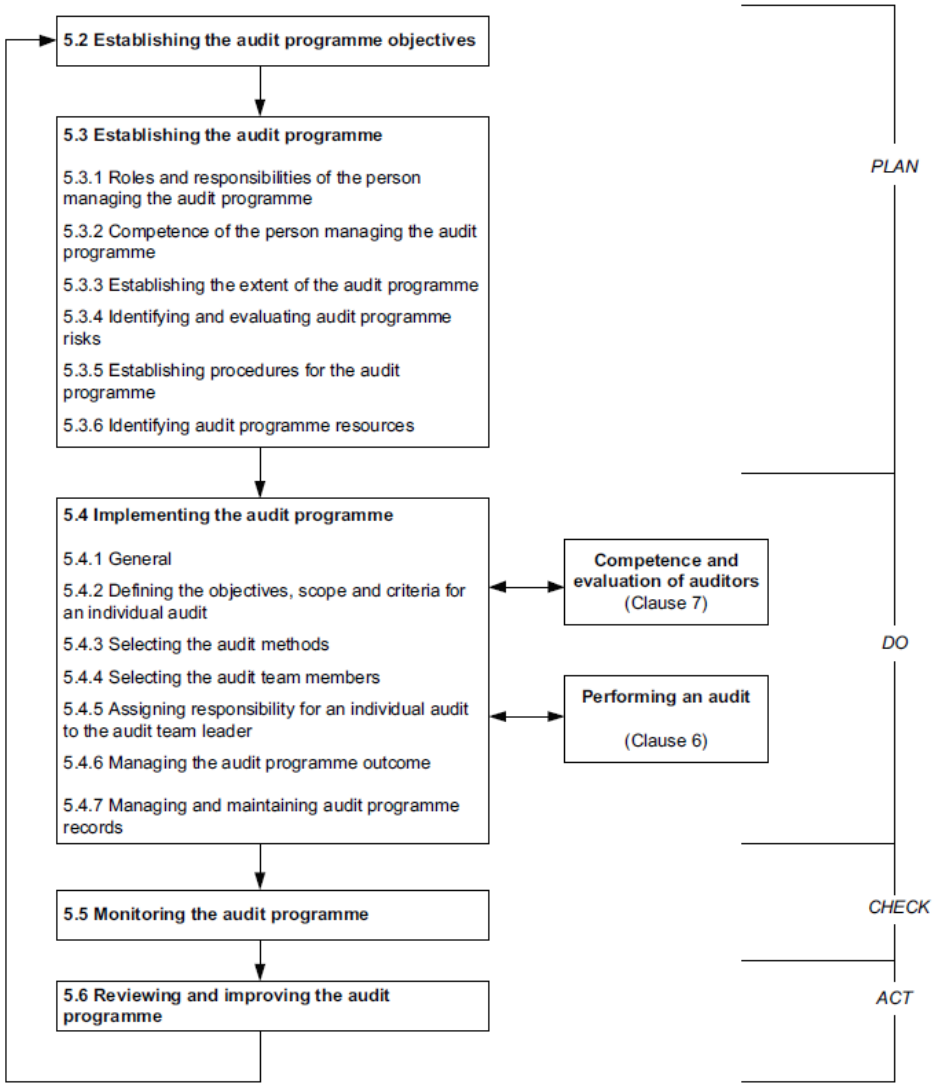
- Realización de una auditoría:
  - Planificación, realización revisiones, hallazgos, informe, etc.

- Competencia y evaluación de los auditores
  - Conocimientos del líder y del equipo, evaluación, mantenimiento y mejora de la competencia, etc.

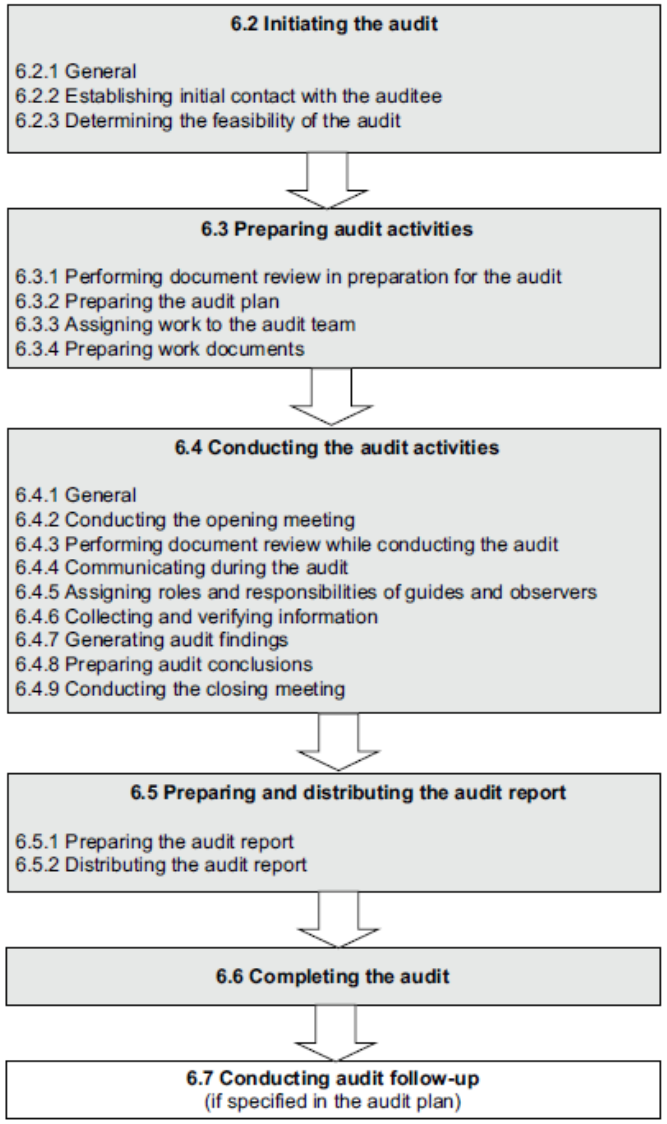
Tabla 1 — Tipos distintos de auditoría

Auditoría de primera parte	Auditoría de segunda parte	Auditoría de tercera parte
Auditoría interna	Auditoría externa de proveedor	Auditoría de certificación y/o acreditación
	Otra auditoría externa de parte interesada	Auditoría legal, reglamentaria o similar

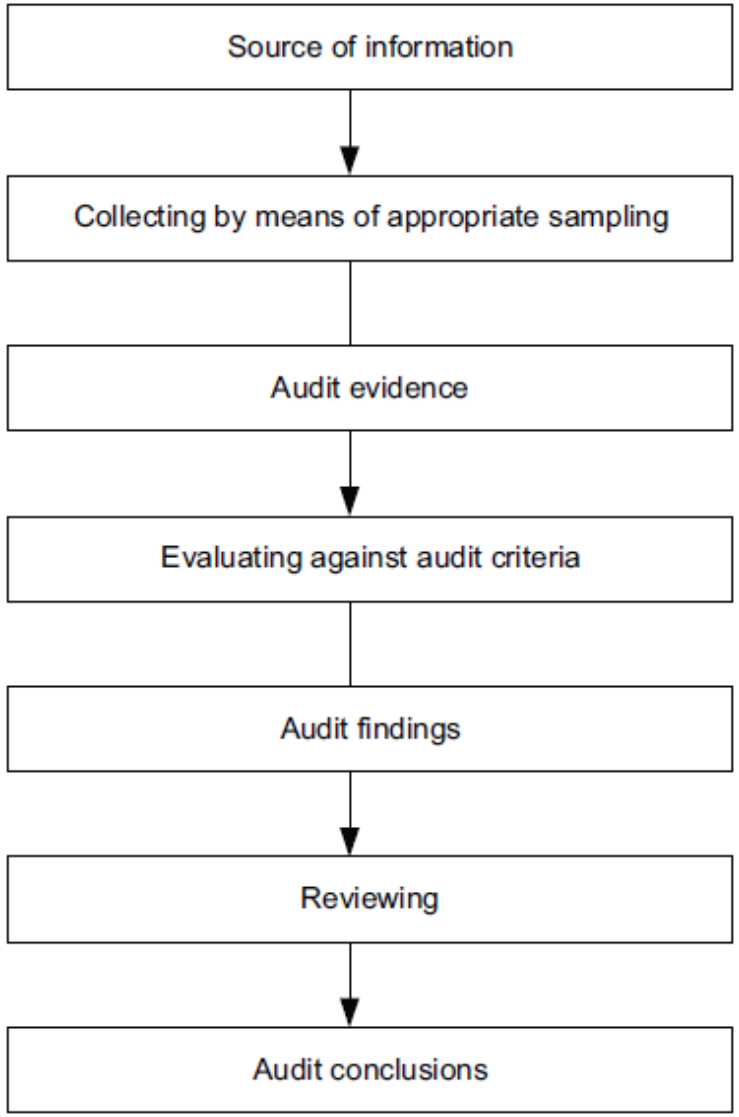
Programa de auditorías



Realización de una auditoría

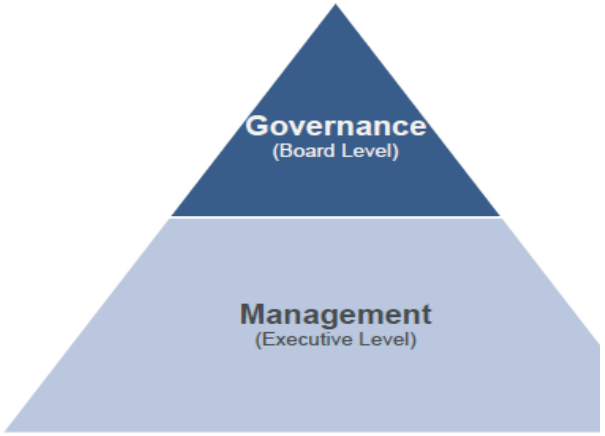


Recopilación de información



COBIT 2019

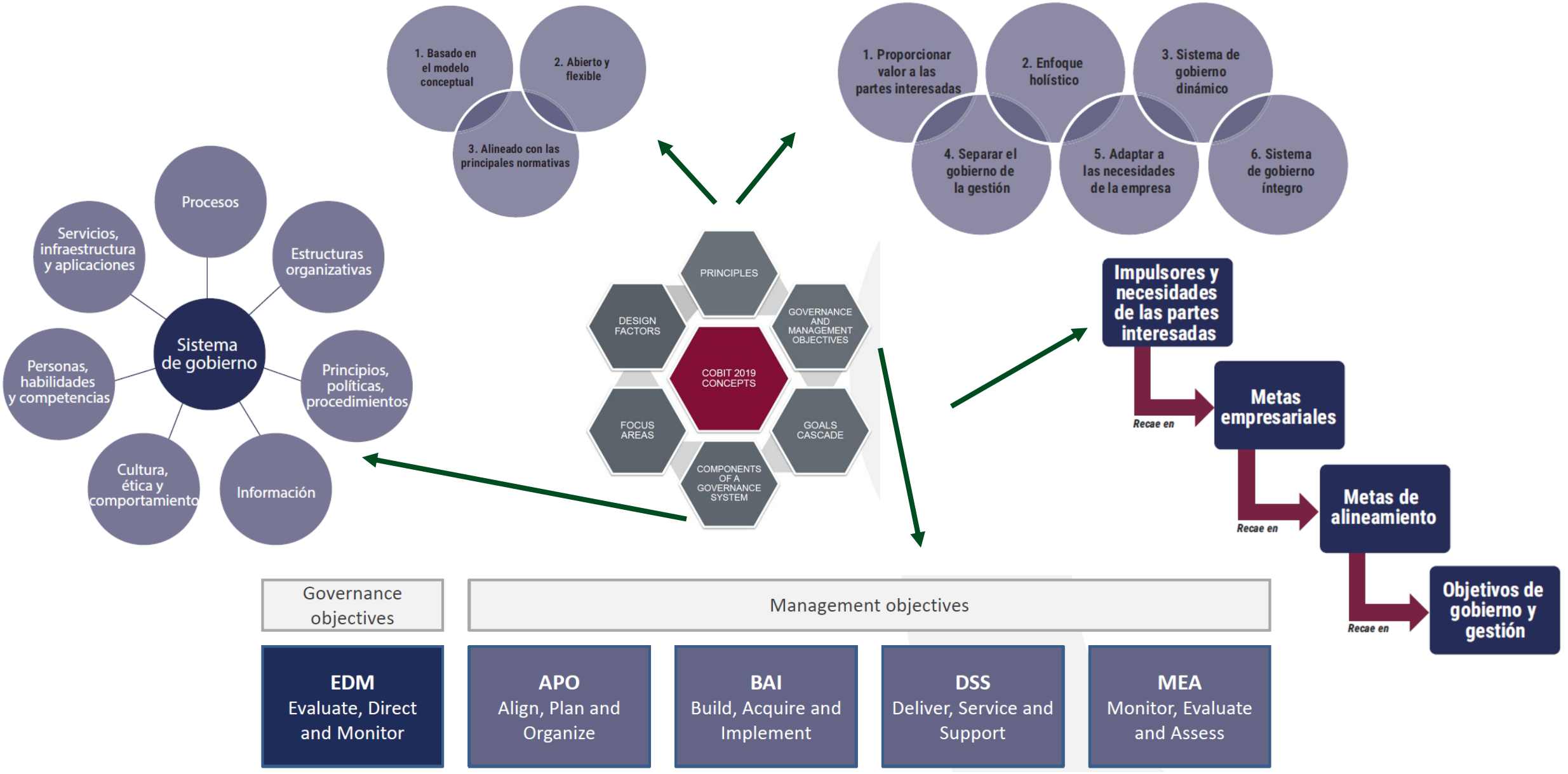
- Control Objetives for Information (and related) Technologies.
- Metodología de ISACA (Information System Audit & Control Association).
- Marco de buenas prácticas para el Gobierno empresarial de la Información y la Tecnología (EGIT, Enterprise governance of I&T).
- Proporciona a los auditores de TI una metodología estructurada y exhaustiva para evaluar los controles de TI, gestionar los riesgos asociados con la información y la tecnología, y asegurar la alineación de TI con los objetivos de negocio.



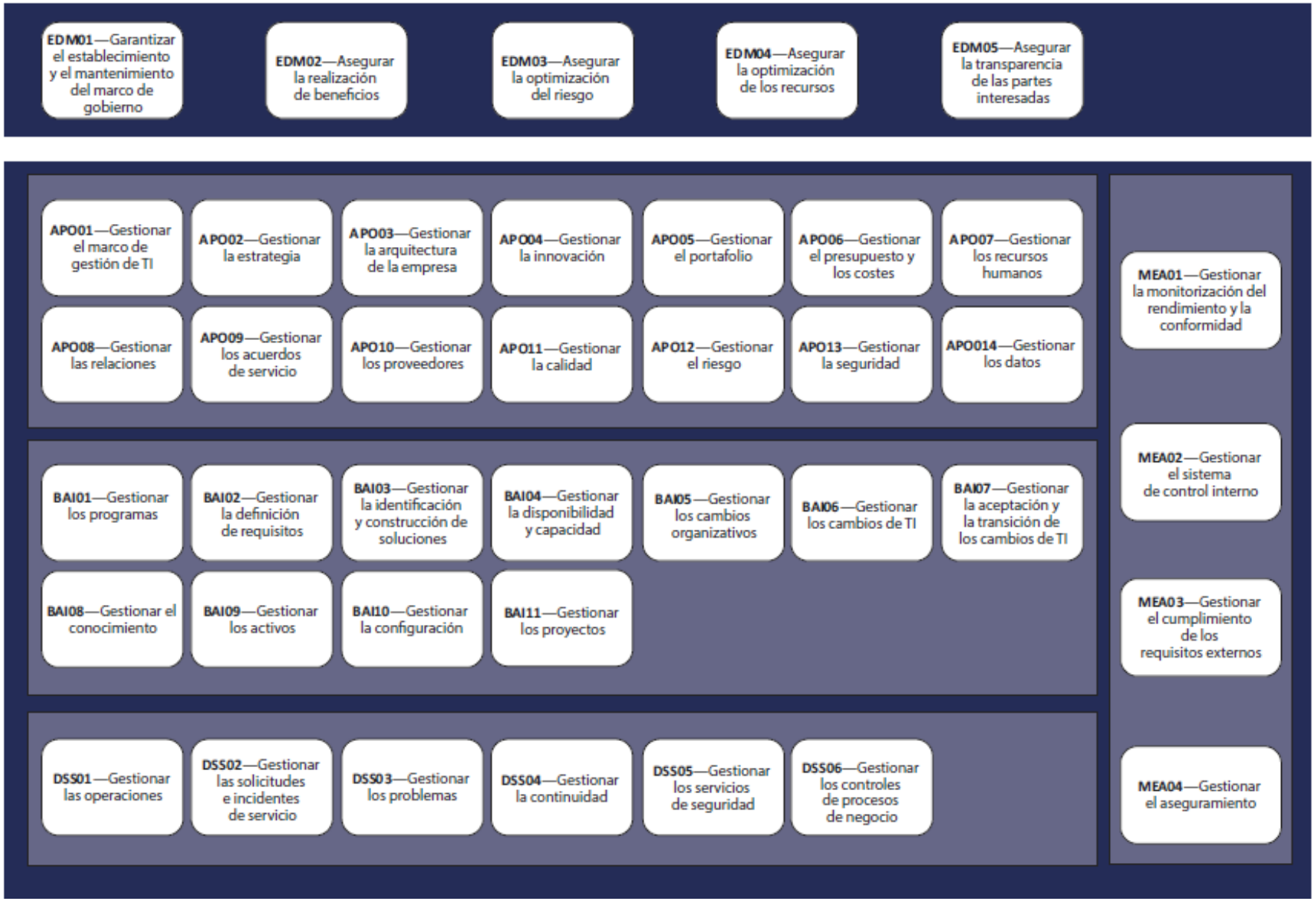




COBIT 2019


1. Basado en el modelo conceptual
2. Abierto y flexible
3. Alineado con las principales normativas
1. Proporcionar valor a las partes interesadas
2. Enfoque holístico
3. Sistema de gobierno dinámico
4. Separar el gobierno de la gestión
5. Adaptar a las necesidades de la empresa
6. Sistema de gobierno íntegro
Procesos
Servicios, infraestructura y aplicaciones
Estructuras organizativas
Sistema de gobierno
Personas, habilidades y competencias
Principios, políticas, procedimientos
Cultura, ética y comportamiento
Información
PRINCIPLES
DESIGN FACTORS
GOVERNANCE AND MANAGEMENT OBJECTIVES
COBIT 2019 CONCEPTS
FOCUS AREAS
GOALS CASCADE
COMPONENTS OF A GOVERNANCE SYSTEM
Impulsores y necesidades de las partes interesadas
Recae en
Metas empresariales
Recae en
Metas de alineamiento
Recae en
Objetivos de gobierno y gestión
Governance objectives
Management objectives
EDM
Evaluate, Direct and Monitor
APO
Align, Plan and Organize
BAI
Build, Acquire and Implement
DSS
Deliver, Service and Support
MEA
Monitor, Evaluate and Assess

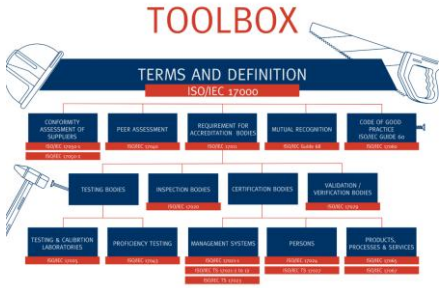
COBIT 2019. Objetivos de gobierno y de gestión



40 objetivos (procesos) de gobierno y gestión, agrupados en 5 dominios.

Evaluación de la conformidad

- También llamada CASCO Toolbox de la ISO, se trata de una serie de estándares relacionado con la evaluación de la conformidad (conformity assessment). La auditoría es un tipo de estas evaluaciones.



- ISO/IEC 17000: Términos y definiciones.
- ISO/IEC 17011: Requisitos para los organismos de acreditación.
- ISO/IEC 17021: Requisitos para los organismos que realizan la auditoría y la certificación de sistemas de gestión (como calidad, seguridad y medio ambiente).
- ISO/IEC 17024: Requisitos para los organismos que realizan certificación de personas.
- ISO/IEC 17065: Requisitos para organismos que certifican productos, procesos y servicios:
  - Las EC del ENS deben estar acreditadas por ENAC para la certificación de sistemas del ENS conforme a la norma UNE-EN ISO/IEC 17065 (ITS conformidad ENS).

CAATs: Computer Assisted Audit Techniques (TAAOs en español)

CAATTs: Computer Aided Audit Tools and Techniques

- Uso de ordenadores, herramientas informáticas, software de auditoría, etc. para automatizar parte de las tareas de una auditoría.
- Aplicaciones utilizadas por el auditor, en parte de sus actividades de auditoría, para procesar los datos relevantes recopilados.
- Equivalente a las herramientas CASE (Computer Aided Software Engineering) de Ingeniería del Software, pero para auditoría.
- Pueden ser productos específicos de auditoría o productos generales con funciones que también ayudan al auditor (procesador de textos, hojas de cálculo).

- Pueden cubrir multitud de aspectos y actividades útiles de una auditoría:
  - Planificación de la auditoría.
  - Cuestionarios para las entrevistas.
  - Técnicas avanzadas de análisis de ficheros y de datos: filtrado, inspección y comparación de datos/contenido, etc.
  - Funciones estadísticas: muestreo, estratificación, frecuencias, etc.
  - Generadores de datos de prueba. Simuladores de situaciones, escenarios.
  - Tracing: análisis de trazas, por donde pasa la información.
  - Análisis de riesgos.
  - Generación y gestión de documentación e informes.

- Ventajas de estas herramientas:
  - Disminución de riesgos por errores de cálculo humano, pérdida de información, etc.
  - Mayor independencia/objetividad.
  - Mayor cobertura y consistencia al usar gran cantidad de datos.
  - Reducción considerable de plazos (ahorro costes).

- Cuando se planifica la auditoría, el auditor debe considerar una combinación apropiada de técnicas manuales y de técnicas de auditoría asistidas por computadora (CAATs).

- En el informe de auditoría se deben describir brevemente las herramientas CAAT utilizadas. Se puede incluir un anexo con una descripción más detallada.

- **Norma SAP 1009** (Statement of Auditing Practice): antigua norma de referencia, propuesta por la IFAC (International Federation of Accountants) planteaba la importancia de las CAATs en auditorías en entornos de sistemas de información. Por eso, también se denominaba norma CAAT.

Algunos productos concretos:

- **IDEA**: Interactive Data Extraction and Analysis.

- **ACL** (Audit Command Language): software de extracción y análisis de datos para auditorías.

- **TeamMate**:
  - Evaluación de riesgos, asignación de recursos, planificación, ejecución, revisión, generación de informes, análisis de tendencias, presentación de informes y almacenamiento.
  - Usada por la IGAE en sus auditorías de cuentas.

- **AuditTool**: web de referencia con conocimientos en auditoría y control interno.

- **Herramientas del CCN**

- Catálogo de soluciones de ciberseguridad del CCN. A destacar en el ámbito de la auditoría:
  - **Inés** y **Amparo**
  - Pilar, Ana y Clara

- *Y además:*

ángeles
Formación y Talento en Ciberseguridad

ATENEA



INÉS: **IN**forme del **E**stado de la **S**eguridad en el ENS.

- Solución desarrollada para la gobernanza de la ciberseguridad, que permite evaluar regularmente el estado de la seguridad de los sistemas del ENS (a.32), además de su adecuación e implantación al ENS.

- La plataforma permite la recogida de información organizada, delegada y supervisada de forma continua a lo largo de todo el año. Consolida datos de >1.000 organismos y >22.000 sistemas.

- Además, permite la creación de un **Plan de Adecuación** al ENS, para priorizar y planificar las tareas a realizar en las primeras fases de la adecuación, entre otras:
  - Elaborar la Política de Seguridad y resto de documentación del marco normativo.
  - Categorización del sistema.
  - Realizar un análisis de riesgos.
  - Solicitar la auditoría para obtener la conformidad (AMPARO).

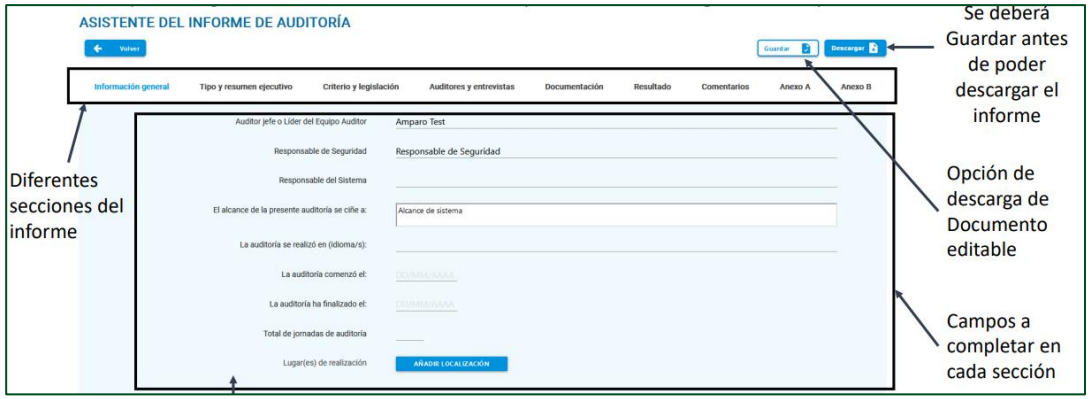


AMPARO

- Asistente para la conformidad del ENS. Asistente de Auditoría Completa.
- Solución desarrollada para la gobernanza de la ciberseguridad (como Inés) de uso exclusivo para las Entidades de Certificación (EC) y Órganos de Auditoría Técnica (OAT).
- Incorpora funcionalidades para facilitar los procesos de auditoría de conformidad y de gestión de la certificación, entre otras:
  - Mantener la comunicación con la organización auditada, ver el estado del sistema y facilitar todo el proceso de auditoría.
  - Remitir y notificar el resumen de hallazgos de auditoría al CCN.
  - Disponer de una sección de Documentos de Conformidad donde poder incorporar el Plan de Auditoría, Informe de Auditoría, Certificado de Conformidad y cualquier otro documento relevante.
  - **Notificar** los **Certificados de Conformidad** para ser publicados en el Portal de Gobernanza.
  - Disponer de un módulo de análisis de datos.

Herramientas del CCN







[Fuente]

PILAR: **P**rocedimiento **I**nformático-**L**ógico para el **A**nálisis de **R**iesgos

- Conjunto de herramientas cuya función es el análisis y la gestión de **riesgos** de un sistema de información siguiendo la metodología **Magerit** (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información).

- Útil para la caracterización y valoración de activos, amenazas, riesgos y salvaguardas.

- Herramienta generalista, pero también **módulos específicos** de cumplimiento de **ENS** y del **RGPD**.

- Diferentes versiones:
  - PILAR: versión íntegra de la herramienta.
  - PILAR Basic: versión sencilla para PYMES y EELL.
  - µPILAR: versión reducida a la mínima expresión para realizar análisis de riesgos muy rápidos.
  - RMAT (Risk Management Additional Tools): herramientas más avanzadas.





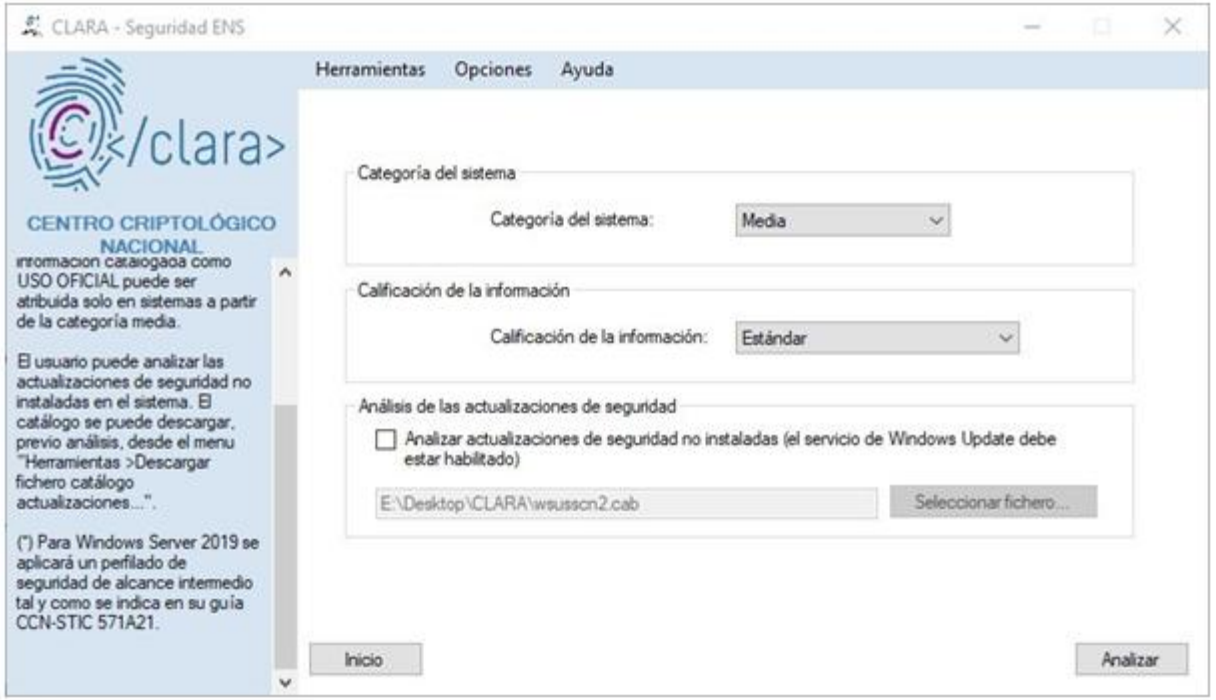
ANA: **A**utomatización y **N**ormalización de **A**uditorías

- Sistema de auditoría continua que tiene por objetivo incrementar la capacidad de vigilancia y evaluar la superficie de exposición.
- Facilita la detección de vulnerabilidades y la notificación de alertas, así como ofreciendo recomendaciones para un tratamiento oportuno de las mismas.
- Evalúa de forma continua y a tiempo real, reduciendo los tiempos de gestión de la seguridad.
- No específica del ENS.



CLARA: Herramienta de auditoría de cumplimiento con el ENS/STIC.

- Evalúa la seguridad a través del ENS y plantillas de guías específicas de las series:
  - 500: Entornos Windows
  - 600: Otros entornos (Linux)
  - 800: ENS
- Para ENS y para Sistemas Clasificados.
- Producto instalable:
  - CLARA ENS para entornos Windows: Windows 7, 10, 11, Windows Server 2019, 2022, 2025.
  - CLARA ENS LINUX para entornos Linux (CentOS, RedHat 7 u 8).
- Actualizada en enero de 2025.



Ángeles

- Portal de formación y ciberseguridad.
- Diferentes tipos de cursos, itinerarios formativos, gamificación, simuladores, webinars (apoyándose en Vanesa, herramienta de streaming), etc.
- APP móvil disponible.
- En concreto, uno de los cursos disponibles se titula Auditorías en el ENS.

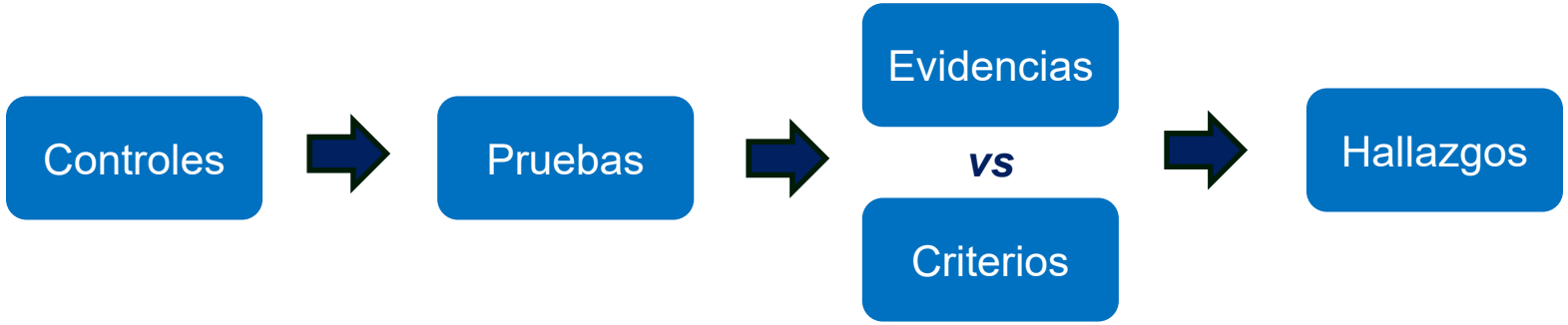




Resumen 1/3

- Conceptos: Auditoría (tipos), controles, pruebas.

- Fases:
  1. Planificación
  2. Ejecución
  3. Informe



- Equipo auditor:
  - Jefe Auditor: 4 años experiencia
  - Auditores
  - Técnicos expertos

- Auditoría LOPD: no obligatoria, solo AEPD.







- Auditoría ENS:
  - Cada 2 años auditoría ordinaria.
  - Sistemas categoría BÁSICA: vale autoevaluación. Declaración conformidad.
  - Sistemas categoría MEDIA o ALTA: auditoría formal. Certificación conformidad.

Resumen 2/3

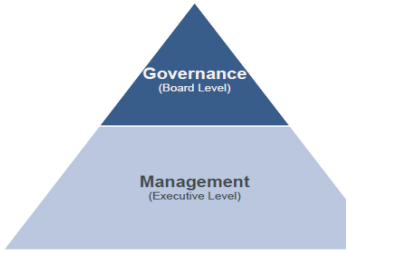
- ITS Auditoría:
  - Hallazgos: No conformidades mayores, menores y observaciones.
  - Dictamen:
    - Favorable
    - Favorable con no conformidades: presentar Plan Acciones Correctivas antes de 1 mes.
    - Desfavorable: auditoría extraordinaria antes de 6 meses.

- Guías CCN STIC: **802**, 808 (checklist), 809 (distintivos, Aprobación Provisional de Conformidad), 825 (vs. 27000), 122 (OAT públicos), IC-01/19 (criterios generales), etc.

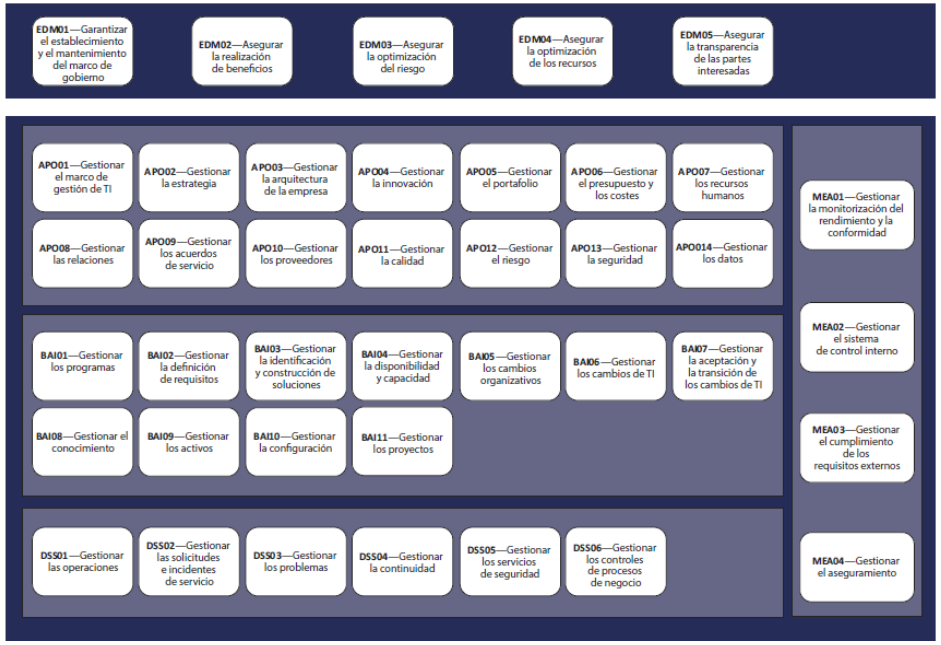
- Internacional:
  - ISO 27000 (conceptos), 27001 (requisitos), 27002 (controles).
  - ISO 15408. Common Criteria, usado por OC-CCN.
  - ISO 19011 (directrices auditoría)
  - ISO 17000. Evaluación de la conformidad. 17065

Resumen 3/3

COBIT 2019







CAATs

IDEA

Wolters Kluwer TeamMate

ACL
Data you can trust. Results you can see.

CCN-CERT
centro criptológico nacional

</inés>
Informe de Estado de Seguridad en el ENS

</amparo>
Seguridad y conformidad del ENS

</pilar>
Análisis y gestión de riesgos

</clara>
Cumplimiento ENS/STIC en Sistemas Windows

</ana>
Automatización y normalización de auditorías

ángeles



CEF.-

Gracias por vuestra atención

udima
UNIVERSIDAD A DISTANCIA DE MADRID